

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: Security Incident Response Policy
Status: Active
Policy Owner: IS Security and Compliance
Original Issue Date: 04/24/2023

SOP# CSISSEC007
Version: 1.0
Department: IT
Last Review: 11/24/2025

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Final Revision	06/07/2023
2	Sarah Ward	Added Related Doc – Cyber Incident Response Plan	09/01/2024
3	Diptanil Paul	Annual Review	09/25/2024
4	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History..... 1

1. Purpose 3

2. Management Responsibilities..... 3

3. Security Incident Response Policy 3

 3.1. Security Incident Definition.....3

 3.2. Handling Information Security Incidents3

 3.3. Reporting Security Incidents3

 3.4. Escalation to the Information Security team3

 3.5. Notification to Legal3

 3.6. Incident Response Team3

 3.7. Cooperation4

 3.8. Incident Response Training4

 3.9. Incident Response Testing4

 3.10. Incident Tracking4

 3.11. Security Incident Classification4

 3.12. Incident Response Plan.....4

Appendix A4

Appendix B.....6

Appendix C.....8

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

The Security Incident Response policy establishes the general requirements and methods for identifying, reporting, responding, and tracking Security Incidents related to Company Information Systems wherever they reside, including but not limited to third party service provider's technology infrastructures.

2. Management Responsibilities

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party workers are aware of, and agree to abide by, the Company's requirements for Incident Management and that incidents are handled in accordance with the requirements of this policy.

3. Security Incident Response Policy

3.1. Security Incident Definition

A Security Incident is any activity that harms or represents a potential or actual threat to any Company Information System, Company facility, or Company Data. Security Incidents typically meet one or more of the following criteria:

- Any occurrence in a network or system that actually or potentially threatens the Confidentiality, Integrity, or Availability of a Company Information System or Resource
- The successful unauthorized access, use, disclosure, modification, or destruction of Company Data
- The successful interference of system operations in any information system processing information on behalf of Company
- The loss of data through theft or device misplacement
- The loss of data through misplacement of hardcopy documents
- Any unauthorized access to any Company Datacenter
- A violation of Company information security policies

Routine detection and remediation of a malware that has little impact on the day-to-day business is not considered a Security Incident under this policy.

3.2. Handling Information Security Incidents

At the outset, Information Security incidents should be treated in the same way as other types of incidents. For those that have a high impact upon Company Information Systems, the Critical incident process (e.g. Business Interruption Process) should be followed. However, due to the nature of Security Incidents there are various additional steps that are required to effectively manage Security Incidents, which are provided in this policy.

3.3. Reporting Security Incidents

If an incident meets the criteria defined above for a Security Incident, it must be reported immediately to the Company Help Desk at Tel: (603) 354-7500 or via e-mail to Helpdesk@cswg.com. Highest severity events (Appendix B) should be reported to Help Desk as well as issecadmin@cswg.com. Retaliation against any individual for reporting or participating in the investigation of a Security Incident is prohibited.

3.4. Escalation to the Information Security team

Upon the Service Desk receiving a report of a security incident (suspected or actual) the Help Desk will collect (at a minimum) the details below and immediately notify the Information Security Team:

- The suspicious activities observed
- The affected systems and locations
- A point of contact for follow-up questions

All reported Security Incidents must be researched and resolved timely by the Information Security Team and follow the process outlined in the Company Security Incident Response Plan.

3.5. Notification to Legal

Any incidents involving customer data, PII, or other types of Confidential Information must be reported to legal upon discovery. Legal will determine what external notifications are required and provide legal guidance as necessary.

3.6. Incident Response Team

Based on the scope of the incident and impact to C&S Operations, the VP, Security and Service Delivery or their designee shall create an Incident Response team and define their roles and responsibilities. The Incident Response team will follow the Incident Response Plan detailed in Appendix C. For the highest severity events, Business Continuity will convene a conference call to review the incident, business impacts, and departmental actions.

C&S Wholesale Grocers, Inc. and Subsidiaries

3.7. Cooperation

All employees, contractors or vendors involved with the incident (directly or indirectly) must cooperate with and support the Incident Response Team and the Information Security Team during the investigation process.

3.8. Incident Response Training

The Information Security Team shall provide incident response training to all Company staff, including all users of Company Information Systems, System Owners, and members of the incident response team.

3.9. Incident Response Testing

The Information Security Team shall test and document (at least annually) Company's incident response capability to determine incident response effectiveness.

3.10. Incident Tracking

The Information Security Team shall track and document Security Incidents by maintaining records about each incident, the status of the incident, any other information required for evaluating incidents details and trends.

3.11. Security Incident Classification

Incidents shall be classified as detailed in Appendix B. Incident severities will vary based on the specific details of the incident. The severities provided in Appendix B are a starting point.

3.12. Incident Response Plan

The Information Security Team shall document Company's implementation of its incident response capability.

4. Related Documents and Appendixes

Related Documents

- Cyber Incident Response Plan

Appendix A – Departmental Roles and Responsibilities

Role Title	Role description	Members
Technology	Manage Company applications, platforms, products, and Infrastructure as part of the response.	Subject matter experts and leaders from the Technology organization as needed depending on the incident.
Commercial	Manage communications with Company customers in coordination with Legal and Communications.	VP/SVP (by chain) Customer Service
Operations and Logistics	Manage Company operations/partner integrations as part of the response.	VP/SVP (by region)
Procurement	Manage Company operations and communications with vendors/manufacturers as part of the response	VP/SVP
Legal	Identify and file required regulatory or contractual submissions. Liaise with law enforcement (if appropriate). Provide legal guidance.	SVP

C&S Wholesale Grocers, Inc. and Subsidiaries

Role Title	Role description	Members
Information Security	Provide response and incident handling subject matter expertise. Manage security controls (administrative, technical, physical) as part of response.	Sr Mgr/CIO
Incident Response Technical Leads	Execute/Coordinate containment, eradication, and recovery steps. Internal members vary by incident but would include subject matter experts from the technology organization and 3 rd party emergency response services if needed.	Sr Mgr/CIO
Incident Response Leaders	Coordinate response efforts and serve as the main point of contact.	Sr Mgr/CIO
Human Resources	Advise on corporate policy or deal with personnel issues (if required) as part of the response.	VP
Finance	Advise on financial issues associated with the event and track costs	VP
Security	Support personnel issues and support collection of physical evidence	Manager, Corporate Investigation and Compliance
Forensic Investigators	Collect and analyze evidence from the incident.	3 rd party forensic investigators would be hired in coordination with outside counsel.
Communications	Manage external communications (e.g. press releases) in coordination with Legal and the Steering Committee	VP, Change Management and Communication
Business Continuity	Coordinate business continuity efforts to maintain services to customers; support situational awareness across departments (e.g. track actions taken, decisions needed, and issue resolution); support Incident Response Leaders	Katie Murphy, Carmela Hinderaker

C&S Wholesale Grocers, Inc. and Subsidiaries

Appendix B – Incident Categories and Descriptions

Category	Description	Severity	Response
Personally Identifiable Information (PII) or Customer data Exposure	Any incident that involves compromised PII, which is any information about an individual including, but not limited to, education, financial transactions, medical history, and criminal or employment history, and information which can be used to distinguish or trace an individual's identity, such as their name, social security number, date and place of birth, mother's maiden name, biometric records, etc., including any other personal information, which is linked or linkable to an individual. Or any incident that involves customer data.	Highest	Assemble SIRT team immediately and initiate Incident response plan.
Denial of Service/ Business Disruption	An attack that prevents or impairs the authorized use of networks, systems, or applications by exhausting resources; this activity includes being the victim of or participating in the attack.	Highest	Leverage business interruption process, include security as stakeholder, assemble SIRT and initiate incident response plan as needed.
Unauthorized Access	An individual gains logical or physical access, without permission, to a Company network, system, application, data, or other technical resource.	High	Information Security analyst needs to triage and categorize. Does not require the Incident Response team unless the actions create high risk for the organization
Email	An attack executed via an email message or attachment.	High	Information Security analyst executes runbook for e-mail attacks.
Physical	Any incident that involves the unauthorized access of a Company datacenter or the interference of a physical security control at	High	Information Security analyst needs to triage and categorize.

C&S Wholesale Grocers, Inc. and Subsidiaries

	a Company facility that puts Company Information Systems at risk.		
Malicious Code	A virus, worm, Trojan horse, or other code-based malicious entity that successfully infects a host. Support is not required to report malicious code that has been successfully quarantined or remediated by antivirus software.	<u>Situational:</u> Medium - for single and unique instances High - for outbreaks Highest - for outbreaks that are disrupting business operations	Information Security analyst works with the Help Desk to remediate. SIRT and response plan only needs to be put in motion if there is an outbreak disruption business operations (e.g. Ransomware)
Scans/Probes/ Attempted Access	Any unauthorized activity that seeks to access or identify a Company computer, open ports, protocols, service, or any combination for later exploit.	Medium	Information Security analyst needs to triage and categorize.
Investigation	Any computer or network activity that is potentially malicious or computer or network activity that an associate believes should be reviewed by Information Security.	Medium	Information Security analyst needs to triage and categorize.
Loss or Theft of Equipment	The loss or theft of a computing device or media used by the organization.	<u>Situational:</u> Medium Highest - if laptop is not encrypted and contains PII or customer data.	Information Security analyst works with the Help Desk / IT to resolve..
NotiOther	An attack does not fit into any other vector.	Medium	Information Security analyst needs to triage and categorize.
Inappropriate Usage	An individual violates acceptable use of any Company computer or network per the Acceptable Usage Policy.	Low	Information Security analyst needs to triage and categorize. Does not require the Incident Response team unless the actions create high risk for the organization

C&S Wholesale Grocers, Inc. and Subsidiaries

Appendix C – Security Incident Workflow

